Skolopals Tutoring Centre — POPIA Policy

Protection of Personal Information Act 4 of 2013 (South Africa)

Responsible party	Skolopals Tutoring Centre
Version	1.0 — Draft for review
Date	2026-10-20
Review cycle	Annually, or on any material change to processing
Status	⚠️ **Not for publication until the `[TO CONFIRM]` fields are completed and a legal review is done.**

Fields to complete before publication

Settled: the Information Officer is **Winnie Thobela**, owner and centre manager — POPIA's default for a private body. Three values remain.

> The phone number below (067 244 7296) is taken from RFQ NWBRT/2026/10 and is published in this notice as the contact for data subject requests. Confirm it is the right number to publish for that purpose, rather than a personal line.

Field	Needed for
~~owner / centre manager full name~~ **Winnie Thobela** ✅	Named as Information Officer on the notice
`[TO CONFIRM: Information Officer email and phone]`	Data subject requests and complaints. **Use a business address, not a personal one** — it is published and becomes the service address for legal requests
`[TO CONFIRM: registered business name and registration number]`	Identifying the responsible party
~~centre physical address~~ **10 Plumbago Street, Damonsville** ✅	Service address for requests, and the invoice footer
`[TO CONFIRM: date registered with the Information Regulator]`	Evidence of s55 compliance

> This document is prepared as a working draft by a non-lawyer. POPIA carries fines of up to R10 million and criminal liability for serious contraventions, and this centre processes children's data,

> which the Act treats as a prohibited category absent valid consent. **Have an attorney review it before it goes live.**

Part A — Privacy Notice

This is the public-facing notice. It is the content for the `/privacy` page.

A1. Who we are

Skolopals Tutoring Centre (`[TO CONFIRM: registered name and registration number]`) is an after-school education support centre at 10 Plumbago Street, Damonsville, Brits, North West. We are the **responsible party** for the personal information described in this notice.

Information Officer: Winnie Thobela, owner and centre manager
Email: `[TO CONFIRM: business email]` · **Phone:** 067 244 7296
Address: 10 Plumbago Street, Damonsville, Brits, North West

A2. Who this notice is about

We process personal information about four groups:

- **Learners** — the children who attend our centre, from Grade R to Grade 12
- **Parents and guardians** — the adults who register learners and pay fees
- **Tutors and staff** — the people we employ
- **Enquirers** — anyone who contacts us through our website

A3. What we collect

Category	What	About whom
Identity	Full name, date of birth, grade, school attended, home language	Learners
Contact	Name, phone, email, physical and postal address	Parents, guardians, tutors, enquirers
Relationship	Which guardian belongs to which learner, who the primary and billing contacts are	Learners, guardians
Safety	Emergency contacts; authorised collectors and their contact details; arrival and collection times	Learners
Health	Allergies, medical conditions and any accommodation a learner needs	Learners
Academic	Assessment results, achievement levels, individual learning plans, termly reports, tutor observations	Learners
Attendance	Presence, absence, lateness and excused absence per session	Learners

Category	What	About whom
Financial	Invoices, payments, payment method and reference, account balance	Guardians
Employment	Qualifications, references, identity documents, police clearance, pay rate	Tutors
Communication	Messages exchanged through the portal, enquiries submitted	All
Technical	Login credentials (passwords are stored hashed, never in readable form), session records	Account holders

We do **not** collect payment card details. Fees are paid by EFT or cash and recorded manually. No card number ever enters our systems.

A4. Children's information — and your consent

This is the most important section of this notice.

Most of the people we hold information about are children. Section 35 of POPIA prohibits processing a child's personal information **unless a competent person — normally a parent or legal guardian — has consented.**

So:

- We will not register a learner, run an assessment, or place a child in a class **until the parent or guardian has given written consent** through our enrolment form.
- Consent is requested **separately for each purpose**. You can agree to the tutoring and decline, for example, the use of your child's photograph in our marketing, and your child will be enrolled exactly the same way.
- **You may withdraw consent at any time**, in writing to our Information Officer. We will stop the relevant processing. Where consent is withdrawn for processing we need in order to teach your child safely, we will tell you what that means for the enrolment before acting on it.
- Where a learner aged 13 or over is given their own login, **the guardian's consent is still what makes the processing lawful.** The learner's own account gives them access to their timetable, their reports and their messages — nothing about siblings, and nothing about billing.

Health information

Allergies and medical conditions are **special personal information** under section 26 of POPIA and are subject to a higher standard. We collect them only because we need them to look after your child safely on our premises, and we process them under section 27(1)(a) — your explicit consent — and section 27(1)(d), protection of a vital interest.

Health information is visible **only to the centre manager and administrators**. Tutors are not given access to it through the system. Where a tutor must know something to keep a child safe during a session, the centre manager tells them directly.

A5. Why we process your information, and on what basis

Purpose	Lawful basis (POPIA s11)
Registering a learner and managing the enrolment	Performance of a contract; guardian consent (s35)
Timetabling, teaching and marking attendance	Performance of a contract
Assessing learners and producing reports	Performance of a contract; guardian consent
Keeping children safe — emergency contacts, controlled collection	Protecting a vital interest (s11(1)(d)); legal obligation
Health and allergy management	Explicit consent (s27(1)(a)); vital interest (s27(1)(d))
Invoicing, collecting fees and keeping accounts	Performance of a contract; legal obligation (tax)
Employing and paying tutors	Performance of a contract; legal obligation
Responding to enquiries	Legitimate interest (s11(1)(f))
Marketing to existing parents	Legitimate interest, with opt-out on every message
Using a learner's photograph or work in marketing	**Separate, specific, opt-in consent.** Never bundled with enrolment

We will not use your information for a new purpose that is incompatible with the one we collected it for, without coming back to you first.

A6. Who we share it with

We do not sell personal information. We share it only as set out here.

Our service providers (operators under POPIA s20):

Provider	What they do	Where
Supabase	Hosts our database, user accounts and uploaded documents	**London, United Kingdom**
Vercel	Hosts and serves our website	Global edge network

Others:

- **A learner's own guardians** — each guardian linked to a learner can see that learner's attendance, assessments and reports.
- **The tutor teaching your child** — sees the learner's name, grade, academic records and attendance for the classes they teach. Tutors cannot see your billing information, your other children, or health notes.
- **Authorities** — where we are legally obliged to disclose, or where a child's safety requires it.

We do not disclose a learner's information to anyone else, including a person claiming to be a relative, unless they appear on the authorised collector list you gave us.

A7. Your information leaves South Africa

Our database is hosted by Supabase in **London, United Kingdom**. This means your and your child's personal information is stored outside South Africa.

Section 72 of POPIA permits this where the receiving country's law, or a binding agreement with the recipient, provides protection substantially similar to POPIA. The United Kingdom's data protection regime meets that standard, and our agreement with Supabase binds them to equivalent safeguards.

By consenting to the enrolment, you consent to this transfer. If you would prefer your child's information not to leave South Africa, contact our Information Officer — we will tell you honestly what we can and cannot offer.

A8. How long we keep it

We keep learner and account records for **5 years** after a learner leaves the centre. This matches the period we must keep financial records for the South African Revenue Service, and means we can still answer a request for a reference or a historical report.

Record	Kept for
Learner identity, academic records, reports, attendance	5 years after leaving
Health notes and authorised collectors	5 years after leaving
Invoices, payments and accounting records	5 years from the end of the tax year
Tutor employment records	5 years after employment ends
Enquiries that do not become enrolments	12 months
Portal messages	5 years
Marketing consent records	Until withdrawn, then 3 years as proof of the withdrawal

After the period ends, records are deleted or anonymised so an individual can no longer be identified.

A9. How we protect it

- Access is controlled at the database level, so a parent's account can only ever return that parent's own learners — this is enforced by the system, not only by the screens.
- Passwords are stored hashed. Nobody at Skolopals can see your password.
- Health notes, identity documents and police clearances are restricted to administrators.
- Uploaded documents are held in private storage that is not publicly reachable.
- All traffic between you and our website is encrypted.
- We log who records a payment, marks a register and publishes a report.

No system is perfectly secure. If a breach affects your information, we will notify you and the Information Regulator as section 22 requires.

A10. Your rights

You may:

- **Ask what we hold** about you or your child, and get a copy
- **Correct or delete** information that is wrong, misleading, outdated or excessive
- **Object** to processing based on legitimate interest
- **Withdraw consent** at any time
- **Opt out of marketing**, on any message
- **Complain** to us, and then to the Information Regulator

Write to our Information Officer at `[TO CONFIRM: email]`. We will respond within **30 days**. There is no charge to ask what we hold; a reasonable fee may apply to copies, as PAIA allows.

A11. Complaining to the Regulator

If you are not satisfied with our response:

The Information Regulator (South Africa)
JD House, 27 Stiemens Street, Braamfontein, Johannesburg, 2001
Complaints: `complaints.IR@justice.gov.za` · Enquiries: `enquiries@inforegulator.org.za`

> Verify these details against inforegulator.org.za before publishing — the Regulator's contact details have changed before.

A12. Changes

We will post any change here and, where it materially affects you, tell you directly. This notice was last updated on `[date of publication]`.

Part B — Internal Compliance Annex

Not published. This is how the centre actually meets the obligations in Part A.

B1. Information Officer

Information Officer	**Winnie Thobela**, owner and centre manager. This is POPIA's default: s1 makes the head of a private body the Information Officer, and s55 attaches the duties to that person automatically
Deputy	**None appointed.** Not required, and unnecessary at current scale. Revisit at the plan's Phase 2 staffing (40–50 learners, when part-time administration is hired) so data subject requests aren't single-threaded through one person
Registered with the Regulator	`[TO CONFIRM: date]` — ⚠️ **Mandatory under s55 and the most commonly missed obligation for small businesses.** The role exists by operation of law whether or not you register; registration is the separate step. Free, done online at the Regulator's portal

Duties: encourage compliance, deal with Regulator requests, handle data subject requests within 30 days, run an annual assessment, maintain the PAIA manual, and ensure staff are trained.

Single-person risk. With no deputy, a data subject request or a breach arriving while the owner is unavailable still runs against the statutory clock. Until a deputy is appointed, the mitigation is that the Information Officer mailbox is monitored and the breach procedure in B6 is written down rather than held in one person's head.

B2. Operator register (s20–21)

Each operator must be under a **written contract** obliging them to process only on our instructions and to maintain security safeguards.

Operator	Purpose	Location	Written contract	Action
Supabase	Database, auth, document storage	eu-west-2, London	Standard DPA in their terms	Accept and file the DPA
Vercel	Website hosting	Global edge	Standard DPA in their terms	Accept and file the DPA
`[email provider — not yet chosen]`	Invoices, reminders, report notifications	TBD	—	**Assess before selecting.** Prefer a provider with an SA region or a solid DPA

B3. Cross-border transfer assessment (s72)

Finding. The Supabase project `dhmjzshlznhqohvkdcpz` is in **eu-west-2 (London)**. All learner data — including children's health information — is stored outside South Africa.

This is lawful but must be documented. Section 72 permits the transfer on three independent grounds, and we rely on all three:

1. **s72(1)(a)** — the recipient is subject to a binding agreement providing substantially similar protection. Supabase's DPA, plus UK GDPR, meets this.
2. **s72(1)(b)** — the data subject consents. Captured at enrolment (see B8).
3. **s72(1)(c)** — the transfer is necessary to perform the contract with the data subject.

Options, if you would rather reduce the exposure:

Option	Effect	Cost
Stay in London, rely on s72 (current)	Lawful, documented, nothing to do	None
Move the project to a different Supabase region	Supabase has no South African region, so data still leaves SA. No real gain	A migration, no benefit
Self-host Postgres in South Africa	Data stays in SA; removes the s72 question entirely	Significant — you lose managed Auth, Storage and backups

Recommendation: stay where you are and rely on s72, with the consent wording in B8. Revisit only if a school partnership or a funder requires local residency.

B4. Retention implementation

Retention is enforced by the system, not by memory.

- `data_retention_policies(record_class, retention_months, basis)` — seeded from the table in A8
- `learners.left_on` starts the clock; `v_retention_due` lists what is now past its period
- A scheduled purge job runs monthly, writes to `data_retention_log`, and **requires admin confirmation before deleting** — nothing is destroyed silently
- Deletion anonymises rather than drops rows where a record is needed for aggregate KPIs, so historical attendance and revenue figures survive the purge

> **Worth revisiting.** POPIA's minimality principle (s10) argues for holding children's health notes and authorised-collector details for less than 5 years, since neither serves the tax purpose that justifies the 5-year period. You chose a single 5-year rule for simplicity, which is defensible. If you later want the stronger position, shortening just those two record classes is a one-row change to `data_retention_policies`.

B5. Security safeguards (s19) mapped to the build

Safeguard	Implementation
Access control	Row-level security on every table. Parent sees only their learners; tutor only their classes; health notes and tutor documents admin-only
Authentication	Supabase Auth; hashed passwords; **enable leaked-password protection** (currently off — see the README)
Encryption	TLS in transit; encryption at rest by the host
Private storage	Tutor documents in a private bucket, admin-read only
Audit trail	`marked_by`, `recorded_by`, `published_at`, `set_by` on registers, payments, reports and pro-rata overrides
Least privilege	Tutors have no billing access at all; learner logins are the narrowest role
Backups	Supabase automated backups; restore tested before go-live

B6. Security compromise procedure (s22)

On discovering or suspecting a breach:

1. **Contain** — revoke keys, suspend affected accounts, stop the leak.
2. **Assess** — within 24 hours, record what was accessed, whose data, and how many people.
3. **Notify the Regulator** — in writing, as soon as reasonably possible.

4. **Notify data subjects** — in writing, unless the Regulator directs otherwise. For learners, notify the guardians. State what happened, what was exposed, what we have done, and what they should do.
5. **Record** in the breach register.
6. **Review** — what changes stop it recurring.

A breach register is maintained from go-live, even if empty.

B7. Data subject request procedure

Step	Owner	Deadline
Log the request	Information Officer	Same day
Verify identity — and, for a learner, that the requester is a linked guardian	Information Officer	3 days
Gather the records	Admin	14 days
Respond	Information Officer	**30 days**

Requests for a learner's information are only answered to a guardian linked to that learner in `learner_guardians`. A request for correction that affects an academic record is actioned as an appended correction, never by silently overwriting a published report.

B8. Consent capture — what the enrolment form must collect

The enrolment flow (`/enrol`) must record each of these **separately**, into a `consents` table with `consent_type`, `granted`, `granted_at`, `granted_by`, `withdrawn_at` and the policy version:

Consent	Required to enrol?	Wording
Processing the learner's personal information (s35)	**Yes**	"I am the parent or legal guardian of this learner and I consent to Skolopals processing their personal information as described in the Privacy Notice."
Health and allergy information (s27)	**Yes, if any is given**	"I consent to Skolopals holding my child's health and allergy information so that staff can keep them safe."
Storing information outside South Africa (s72)	**Yes**	"I understand that Skolopals' systems are hosted outside South Africa, in the United Kingdom, under protections substantially similar to POPIA."
Photographs and schoolwork in marketing	**No — optional**	"I consent to Skolopals using photographs of my child or their work in its marketing. I may withdraw this at any time."
WhatsApp and email updates	**No — optional**	"I would like to receive updates about programmes and centre news."

The optional consents must default to off and must not block submission. Bundling them into the enrolment consent is the single most common POPIA failure and would invalidate the consent entirely.

The notice version is stored with each consent, so when the policy changes you know who consented to what.

B9. Implementation checklist

Database and app work that this policy requires:

- ☐ `consents` table with per-purpose records and policy versioning
- ☐ `data_retention_policies`, `v_retention_due`, `data_retention_log`, monthly purge job with admin confirmation
- ☐ `learners.left_on` to start the retention clock
- ☐ Separate, unbundled consent checkboxes on `/enrol`, optional ones defaulting to off
- ☐ Admin-only RLS on `learner_medical_notes`, `tutor_documents`, `tutor_references`
- ☐ Tutors explicitly denied access to health notes and all billing tables
- ☐ Marketing opt-out link on every bulk message
- ☐ Parent-facing "Download my data" export
- ☐ Breach register
- ☑ `/privacy` renders Part A of this document — consent wording and retention periods are read from the database, so the notice and the enrolment form cannot disagree
- ☐ Enable leaked-password protection in Supabase Auth

Business actions outside the code:

- ☐ **Register the Information Officer with the Information Regulator** — the owner/centre manager already holds the role by law; registration is the outstanding step
- ☐ Accept and file the Supabase and Vercel DPAs
- ☐ Prepare a **PAIA manual** — a separate legal requirement from this policy
- ☐ Attorney review of Part A before publication
- ☐ Brief all tutors on confidentiality and the collection procedure
- ☐ Add the consent wording to the paper enrolment form, for parents who register in person